PRADITA University

IT40713 · Cloud-Native & Microservices Architecture

Resiliensi dan Disaster Recovery

7 Nopember 2026

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. Mode Kegagalan
3. Pola Resiliensi
4. Multi-AZ dan Multi-Region
5. RTO, RPO, dan Strategi DR
6. Ransomware dan Cadangan
7. Chaos Engineering dan Game Day
8. Aktivitas dan Penutup

PRADITA University

Bila satu pusat data lumpuh malam ini, layanan mana yang harus tetap berjalan besok pagi?

PRADITA University

Tujuan dan Konteks

Tujuan Pembelajaran

PRADITA University

- Mengidentifikasi mode kegagalan dalam sistem terdistribusi dan pola resiliensi untuk menanganinya.
- Menetapkan RTO dan RPO berdasarkan dampak bisnis.
- Memilih strategi DR yang seimbang antara biaya dan risiko.

PDNS 2 Surabaya, Juni 2024

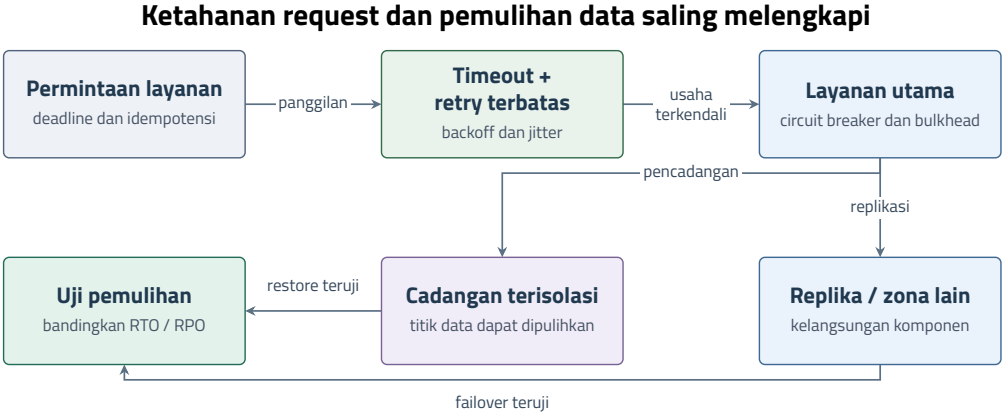
PRADITA University

- 17 Juni: upaya menonaktifkan Windows Defender terdeteksi; 20 Juni: *ransomware* Brain Cipher mulai berjalan.
- Tebusan yang diminta 8 juta dolar Amerika Serikat, sekitar Rp131 miliar.
- 282 instansi pengguna terdampak; layanan keimigrasian termasuk yang pertama pulih.
- Kepala BSSN: hanya 2 persen data di PDNS Surabaya yang memiliki cadangan.
- Pelajaran: cadangan yang tidak lengkap atau tidak diuji sama dengan tidak punya cadangan.

Sumber: ANTARA (27 Juni 2024), CNN Indonesia (26 Juni 2024), CNBC Indonesia (28 Juni 2024).

Diagram Konsep Bab 12

PRADITA University



Replikasi dapat menyalin kerusakan. Cadangan terisolasi dan pengujian restore tetap diperlukan sesuai hasil BIA.

Resiliensi dan Disaster Recovery

PRADITA University

- Resiliensi: tetap melayani, mungkin dengan fungsi terbatas, ketika sebagian komponen gagal.
- DR: rencana, arsitektur, dan latihan untuk pulih dari kejadian besar.
- IGD tetap menerima pasien pukul tiga dini hari, apa pun yang terjadi pada pusat data.
- Pertanyaan dari Bab 1: bagaimana rekam medis dipulihkan bila satu pusat data padam?

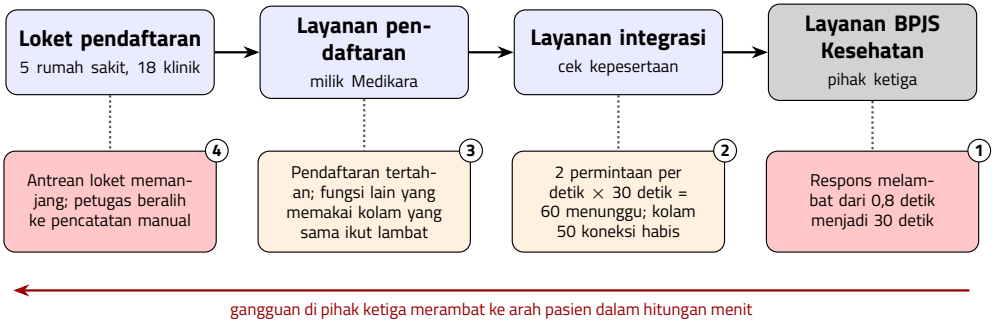
Mode Kegagalan

Kegagalan Parsial dan Latensi Tinggi

- Sistem terdistribusi jarang gagal total; lebih sering gagal sebagian.
- Paling licin: latensi tinggi. Layanan tidak mati, tetapi lambat.
- Permintaan yang menunggu $\approx$ laju $\times$ lama menunggu.
- 2 per detik $\times$ 0,8 detik $\approx$ 2 menunggu; 2 per detik $\times$ 30 detik = 60 menunggu.
- Kolam 50 koneksi penuh dalam sekitar 25 detik.

Analogi: telepon yang dijawab “mohon tunggu” setengah jam lebih merugikan daripada telepon yang tidak diangkat.

Kegagalan Berantai



Titik kegagalan tunggal sering tersembunyi: basis data identitas, sertifikat, satu akun, satu orang.

Contoh Nyata

PRADITA University

- AWS US-EAST-1, 7 Desember 2021: lonjakan koneksi membanjiri jaringan internal.
- Latensi dan *error* naik, lalu memicu lebih banyak percobaan dan pengulangan.
- Kemacetan ikut mengganggu data pemantauan tim operasi.
- CrowdStrike, Juli 2024: pembaruan rusak mengenai sekitar 8,5 juta perangkat Windows.
- Kurang dari 1 persen mesin Windows, tetapi banyak sektor terdampak pada hari yang sama.

Enam Mode Kegagalan

Mode	Contoh di Medikara	Pola penanganan
Kegagalan total	Server farmasi RS Depok mati	Salinan ganda, pindah otomatis
Latensi tinggi	Cek kepesertaan dari 0,8 menjadi 30 detik	*Timeout*, *circuit breaker*
Kegagalan parsial	Satu dari lima kiriman ke SATUSEHAT ditolak	*Retry* dengan *backoff*
Kegagalan berantai	Antrean loket memanjang	*Bulkhead*, batas *retry*
Titik kegagalan tunggal	Satu basis data identitas	Redundansi, *multi-AZ*
Pihak ketiga	Gangguan BPJS Kesehatan, pembaruan vendor	*Graceful degradation*

Kasus Medikara: Gangguan BPJS Merambat ke Loket

PRADITA University

- Senin 08.10: kepesertaan BPJS Kesehatan melambat dari 0,8 menjadi 30 detik.
- Layanan integrasi: 2 permintaan per detik, satu kolam 50 koneksi untuk semua tujuan.
- Kolam penuh dalam 25 detik; aplikasi mengulang tiga kali, petugas menekan “ulangi”.
- SATUSEHAT dan pasien umum ikut tertahan.
- Pukul 09.30: waktu tunggu loket RS Jakarta naik dari 15 menjadi 70 menit.

Tanpa batas waktu, tanpa sekat, tanpa jalur cadangan.

PRADITA University

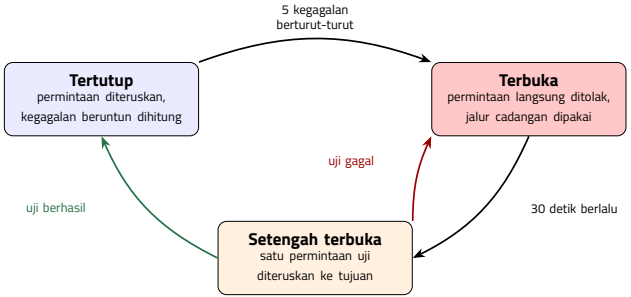
Pola Resiliensi

Timeout dan Retry

- *Timeout*: batas waktu menunggu; lambat diubah menjadi gagal cepat.
- Batas ditetapkan dari data latensi, misalnya persentil ke-99,9 (Brooker).
- *Timeout* 3 detik: paling banyak $2 \times 3 = 6$ permintaan menunggu.
- *Retry* dengan *backoff* dan *jitter*: jeda makin panjang dan acak.
- Bahaya: tiga lapis $\times$ empat percobaan $= 4^3 = 64$ percobaan (buku SRE Google).

Hanya operasi yang aman diulang yang boleh diulang.

Circuit Breaker



Yang terasa di loket. Tertutup: kepesertaan terbaca dalam sekitar 1 detik. Terbuka: jawaban datang seketika, pasien tetap didaftarkan, dan kepesertaan ditandai "periksa ulang". Tanpa pemutus: setiap pasien menunggu sampai batas waktu habis, dan kolam koneksi ikut tertahan.

Bulkhead dan Graceful Degradation

PRADITA University

- *Bulkhead*: sekat sumber daya, seperti sekat lambung kapal.
- Kolam 50 dibagi: 30 BPJS Kesehatan, 10 SATUSEHAT, 10 tujuan lain.
- *Graceful degradation*: fungsi inti tetap jalan dengan mutu diturunkan.
- Pasien tetap didaftarkan; kepesertaan ditandai “periksa ulang”.
- Pemeriksaan interaksi obat tidak pernah dilewati, hanya dikerjakan manual oleh apoteker.

Pendalaman: Simulasi Circuit Breaker

PRADITA University

- Skrip `simulasi-circuit-breaker.py`: satu panggilan per detik, gangguan detik 20 sampai 79.
- Tanpa pemutus: 60 gagal setelah menunggu, total tunggu 228 detik.
- Dengan pemutus (ambang 5, terbuka 30 detik): 6 gagal, 58 dialihkan, 62,8 detik.
- Terbuka detik 24, uji gagal detik 54, tertutup detik 84.
- Harga pemutus: 4 permintaan dialihkan walau tujuan sudah sehat sejak detik 80.

Multi-AZ dan Multi-Region

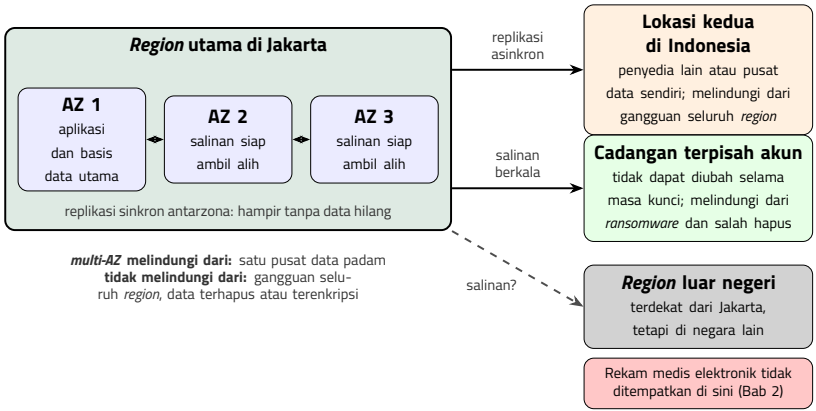
Dua Tingkat Perlindungan

PRADITA University

- *Multi-AZ*: dua atau tiga zona dalam satu *region*; replikasi sinkron.
- *Multi-region*: *region* lain yang jauh; replikasi biasanya asinkron.
- Sinkron: tanpa data hilang, tetapi setiap penulisan menunggu lokasi kedua.
- Asinkron: cepat, tetapi data yang belum terkirim hilang saat bencana.
- AWS: hindari *multi-region* bila *multi-AZ* sudah memenuhi kebutuhan bisnis.

Analogi: genset di basement melindungi dari listrik padam, tidak dari banjir.

Cakupan Perlindungan untuk Medikara



***multi-AZ* melindungi dari:** satu pusat data padam
tidak melindungi dari: gangguan seluruh *region*, data terhapus atau terenkripsi

Kendala Lokasi Data dan Ukuran Data

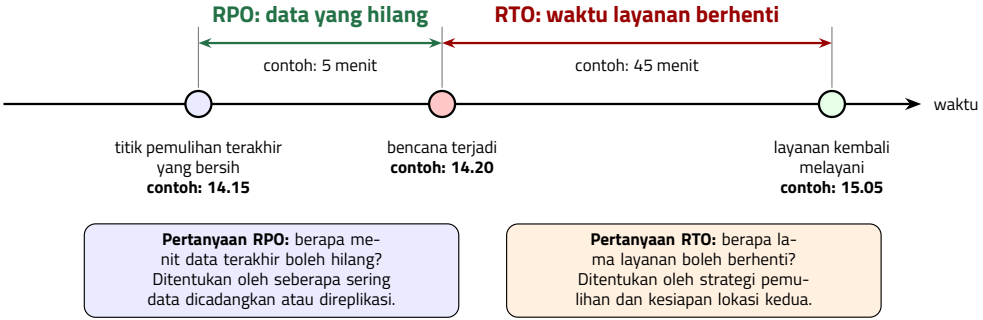
PRADITA University

- Rekam medis ditempatkan di Indonesia (Bab 2); cadangan wajib di tempat berbeda.
- Setiap penyedia global hanya punya satu *region* di Indonesia.
- Lokasi kedua: penyedia lain, pusat data lokal, atau fasilitas sendiri.
- 15 terabyte lewat 1 gigabit per detik: $15 \times 8 \times 10^{12} \div 10^{9} = 120.000$ detik, sekitar 33 jam.
- Data besar harus sudah berada di lokasi kedua sebelum bencana.

PRADITA University

RTO, RPO, dan Strategi DR

RTO dan RPO



RTO harus lebih pendek dari waktu henti maksimum yang dapat ditoleransi (NIST SP 800-34).

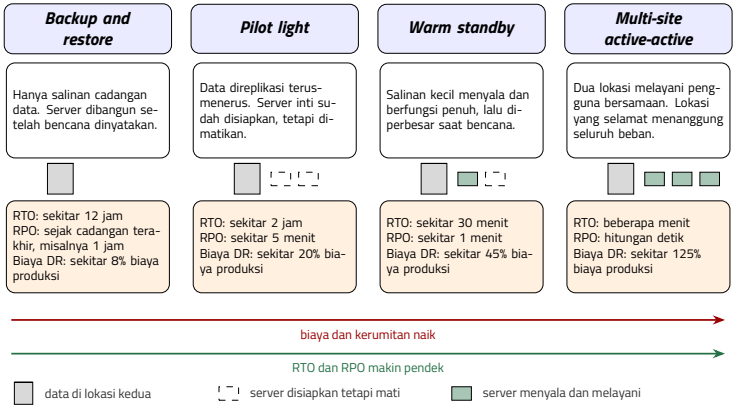
Analisis Dampak Bisnis: Lima Pertanyaan

PRADITA University

1. Apa yang terjadi bila layanan berhenti 1 jam, 4 jam, dan 24 jam?
2. Berapa kerugian finansial per jam?
3. Seberapa besar dampak pada keselamatan pasien?
4. Kewajiban regulasi atau kontrak apa yang terlanggar?
5. Berapa waktu henti maksimum yang masih dapat ditoleransi?

Anggota non-teknis memimpin. Bila biaya pemulihan melebihi biaya kegagalan, strategi tidak perlu diterapkan, kecuali ada kewajiban regulasi (AWS).

Empat Strategi DR



Kasus Medikara: RTO dan RPO Tiga Layanan

Butir	Rekam medis elektronik	Medikara+	ERP keuangan
Kerugian per jam	Rp150 juta	Rp40 juta	Rp15 juta
Keselamatan pasien	Tinggi	Sedang	Rendah
Waktu henti maksimum	2 jam	8 jam	48 jam
RTO dan RPO	1 jam, 5 menit	4 jam, 15 menit	24 jam, 60 menit
Strategi DR	*Warm standby*	*Pilot light*	*Backup and restore*
Biaya DR per tahun	Rp540 juta	Rp120 juta	Rp64 juta

Total sekitar Rp724 juta per tahun, dibandingkan sekitar Rp3,25 miliar bila semuanya *active-active*.

Ransomware dan Cadangan

Replikasi Bukan Cadangan

- *Ransomware* berusaha menemukan lalu menghapus atau mengenkripsi cadangan (CISA).
- Replikasi menyalin keadaan terkini, termasuk kerusakannya.
- Cadangan menyimpan masa lalu, sehingga organisasi dapat kembali.
- CISA: cadangan terpisah dari jaringan, terenkripsi, dan diuji berkala.
- Penyimpanan yang tidak dapat diubah: salah konfigurasi dapat mahal.

Analogi: salinan akta di brankas bank berkunci waktu, bukan di laci meja kerja.

Lima Prinsip Cadangan

Prinsip	Artinya	Cara memeriksa
Lengkap	Semua data kritis, konfigurasi, kunci	Dicocokkan dengan daftar layanan kritis
Terpisah	Akun, kredensial, jaringan berbeda	Admin produksi gagal menghapus cadangan
Tidak dapat diubah	Terkunci selama masa kunci	Percobaan hapus di lingkungan uji ditolak
Terenkripsi	Tidak terbaca bila dicuri	Kunci disimpan terpisah
Teruji	Pemulihan dicoba berkala	Waktu pulih nyata dibandingkan dengan RTO

Aturan praktis 3-2-1: tiga salinan, dua jenis media, satu di luar lokasi utama.

Kasus Medikara: Audit Cadangan

- 46 aplikasi dalam inventaris Bab 4.
- 31 punya jadwal cadangan; 12 pernah diuji pulih dalam 12 bulan terakhir.
- Hanya 3 yang cadangannya berada di akun terpisah.
- Cadangan SIMRS RS Bandung di server yang sama, dapat dihapus admin domain.
- Angka jujur: 3 dari 46 selamat dari *ransomware*.

Chaos Engineering dan Game Day

Chaos Engineering

PRADITA University

- Eksperimen untuk membangun keyakinan bahwa sistem tahan kondisi bergejolak.
- Empat langkah: keadaan normal terukur, hipotesis, peristiwa nyata, cari selisih.
- Cakupan dampak (*blast radius*) ditekan sekecil mungkin.
- Netflix: Chaos Monkey mematikan mesin acak pada jam kerja; Chaos Kong sekali sebulan.
- Hanya pada sistem sendiri atau yang berizin tertulis; layanan mitra disimulasikan.

Game Day dan Syarat Aman

- *Game day*: latihan terjadwal tim teknis dan bisnis; mulai dari latihan meja.
- Medikara: *region* utama tidak tersedia empat jam.
- Temuan: layanan identitas hanya di *region* utama; pulih menit ke-80, RTO 1 jam meleset.
- Syarat: hipotesis terukur, cakupan kecil, kriteria berhenti, izin tertulis.
- Pemantauan berjalan dan cara kembali sudah diuji.

Aktivitas: Rencana Resiliensi dan DR

PRADITA University

1. Ambil dua sampai tiga layanan kritis dari Bab 11 beserta ketergantungannya.
2. Lakukan analisis dampak bisnis dengan lima pertanyaan.
3. Tetapkan RTO dan RPO bersama pemilik bisnis.
4. Pilih strategi DR dan lokasi kedua; perkirakan biaya; petakan pola resiliensi.
5. Susun skenario uji, jalankan latihan meja, tetapkan jadwal uji setahun.

Peran, Luaran, dan Penilaian

- Non-teknis: analisis dampak bisnis, kerugian, keselamatan, regulasi.
- Teknis: pola resiliensi, strategi DR, lokasi kedua, biaya.
- Luaran C4: rencana resiliensi dan DR, skenario uji, jadwal uji pemulihan.
- Bobot: dampak bisnis 30, RTO/RPO dan strategi 30, pola 20, skenario uji 20.
- Berkas: `sources/chapter12/` (templat dampak bisnis, rencana DR, skenario).

Ringkasan

- Latensi tinggi dan kegagalan berantai lebih sering daripada kegagalan total.
- Lima pola resiliensi; pengulangan harus dibatasi.
- *Multi-AZ* untuk satu pusat data; lokasi kedua di Indonesia untuk rekam medis.
- RTO dan RPO dari dampak bisnis; strategi termurah yang memenuhi target.
- Cadangan terpisah dan tidak dapat diubah; rencana dibuktikan lewat uji terjadwal.

Latihan

PRADITA University

1. Jelaskan perbedaan RTO dan RPO dengan contoh layanan rekam medis elektronik.
2. Pada insiden PDNS 2 tahun 2024, hanya sebagian kecil data yang memiliki cadangan. Pelajaran arsitektur dan tata kelola apa yang dapat diambil?
3. Mengapa strategi *multi-site active-active* belum tentu tepat untuk semua layanan Medikara Health?